

Supplementary material for “From Cloud to Assembly Line: Modelling Cyberattack Paths in Automotive Manufacturing as Critical Infrastructure”

1 How each parameter was set

The model carries four kinds of parameter. This section states how each kind was arrived at, so that a reader can judge every value and a panel can replace it.

Initial-access probabilities $p(e)$ for steps out of the actor. Ordered by how often the corresponding entry vector appears in the corpus and in public reporting on manufacturing intrusions. Phishing a supplier is placed above phishing an OEM because suppliers in the corpus are compromised with weaker controls; a trojanised vendor software package is placed near the bottom because no corpus incident used one. The ordering is the claim; the absolute values are the coarse bands of Table 1.

Lateral and descent probabilities. Set from the technical precondition of the step. A step that needs only credentials the actor already holds sits in the H or VH band (a domain member authenticating to its own directory, an engineering workstation downloading a program, a controller driving its own process). A step that needs an exploit sits in M. A step that needs physical presence, a safety key switch or a signed project sits in L.

Detection probabilities $\delta(e)$. These encode the monitoring a mid-sized OEM plant can be assumed to have *before* any control from the catalogue is deployed, which is why S_0 is a baseline and not an unprotected configuration. Steps inside the corporate estate, where endpoint logging is normal, carry higher values than steps inside the cell, where protocol-aware monitoring is the exception. δ is read as detected *and* contained within the actor’s dwell time; an alert nobody acts on is not containment.

Consequence parameters. Anchored on reported outcomes rather than on judgement: the one-day, 14-plant Toyota stoppage at one end of the duration distribution and the five-week Jaguar Land Rover outage at the other. The loss rate per stopped hour and the fixed response costs are the coarsest parameters in the model and the ones a plant should replace first with its own figures.

What the values are not. They are not measurements, and no claim is made that they are the parameters of any specific plant. Experiment E6 of the paper reports how far the conclusions move when every probability is perturbed; conclusions that do not survive that perturbation are not drawn. docs/elicitation-protocol.md in the artefact gives the instrument and procedure for replacing these estimates with a panel’s.

Table 1: The anchored bands. Published estimates are reported against these bands so that a reader can see the granularity actually claimed, and so that a panel re-eliciting the model answers on the same scale.

Band	p : the step succeeds	δ : detected <i>and</i> contained	Effort
VL	0.05 rarely works	0.05 we would not notice	2 h under half a day
L	0.15 needs a specific weakness	0.20 noticed too late	8 h about a day
M	0.35 works about as often as not	0.40 even chance	24 h a few days
H	0.60 usually works	0.60 usually contained	80 h one to two weeks
VH	0.85 almost always works	0.80 almost always contained	200 h over a month

2 Bands

3 Every attack step

4 Controls

5 Consequences

6 Reproducing the results

The artefact at <https://github.com/rikosoo/InfraCriticalCar> regenerates every number, table and figure of the paper. It needs only a CPython 3.9 or newer interpreter and no third-party package.

```
git clone <repository>
cd InfraCriticalCar
python3 experiments/run_all.py          # E1-E7, about ten minutes
python3 experiments/build_paper_assets.py # tables and figures, both languages
python3 experiments/build_supplementary.py
python3 -m pytest                       # 65 tests
```

Monte Carlo experiments use 20,000 campaigns per configuration and a fixed seed (20260916); simulation is deterministic across processes and platforms, which a test in the suite enforces. `experiments/results/summary.json` carries every number the paper quotes, and `data/incidents.csv` carries the corpus with the source URL and consultation date of each record.

Table 2: Every attack step of the reference architecture with its parameters, the anchored band each value falls in, the controls that act on it, the corpus incidents that support it, and the reason the step is modelled. Bands are those of the elicitation instrument: VL, L, M, H, VH.

Step	Technique	p	δ	Effort (h)	Controls	Evidence	Rationale
Vendor remote-access broker $\backslash\{\}$ to\$ Engineering workstation	T0822	0.65 (H)	0.45 (M)	6 (L)	C04 C13	–	Brokered vendor sessions terminate on the engineering workstation
OT jump server $\backslash\{\}$ to\$ Engineering workstation	T1021.001	0.70 (H)	0.40 (M)	4 (VL)	C05 C03	–	The jump server exists to reach engineering hosts
Historian mirror / data broker $\backslash\{\}$ to\$ Process historian	T0885	0.50 (H)	0.45 (M)	8 (L)	C05 C13	–	Mirror and historian exchange process data over a permitted port
Patch, antivirus and update relay $\backslash\{\}$ to\$ Process historian	T1072	0.50 (H)	0.45 (M)	10 (L)	C09 C13	–	The relay pushes packages into site operations on a schedule
External threat actor $\backslash\{\}$ to\$ Object storage and data lake	T1530	0.18 (L)	0.55 (H)	16 (L)	C16	INC-09 INC-10	Discovery of misconfigured object storage
External threat actor $\backslash\{\}$ to\$ Cloud tenant control plane	T1552.001	0.15 (L)	0.45 (M)	24 (M)	C11 C16	INC-19	Cloud secrets exposed in a public code repository
External threat actor $\backslash\{\}$ to\$ Dormant third-party / legacy credentials	T1078	0.30 (M)	0.20 (L)	6 (L)	C12	INC-18 INC-19	Reuse of dormant contractor or legacy integration accounts
External threat actor $\backslash\{\}$ to\$ Internet-facing enterprise application	T1190	0.45 (M)	0.35 (M)	24 (M)	C10 C07	INC-18	Exploitation of an Internet-facing enterprise application
External threat actor $\backslash\{\}$ to\$ Corporate mail service	T1566.001	0.85 (VH)	0.30 (L)	4 (VL)	C07	INC-07	Mail delivery of a lure to a corporate mailbox
External threat actor $\backslash\{\}$ to\$ IT service desk process	T1656	0.35 (M)	0.40 (M)	6 (L)	C01 C15	INC-18	Voice social engineering of the service desk
External threat actor $\backslash\{\}$ to\$ Recruited or coerced insider	T1078	0.06 (VL)	0.35 (M)	40 (M)	C15 C13	INC-08	Recruitment or coercion of a person with plant access
External threat actor $\backslash\{\}$ to\$ Employee workstation	T1189	0.22 (L)	0.40 (M)	8 (L)	C06 C07	INC-07	Drive-by download from an employee browsing session
External threat actor $\backslash\{\}$ to\$ Remote access VPN gateway	T1133	0.38 (M)	0.30 (L)	12 (L)	C01 C02	INC-13	Authentication to remote access with harvested credentials
External threat actor $\backslash\{\}$ to\$ Third-party CRM / customer platform	T1078.004	0.30 (M)	0.30 (L)	10 (L)	C11	INC-17	Abuse of OAuth tokens held by an integrated SaaS application
External threat actor $\backslash\{\}$ to\$ Dealer management platform	T1190	0.25 (M)	0.40 (M)	20 (M)	C11 C10	INC-11	Exploitation of a shared retail SaaS platform
External threat actor $\backslash\{\}$ to\$ OT software and firmware update channel	T1195.002	0.08 (VL)	0.50 (M)	120 (H)	C09 C14	–	Trojanised engineering software or firmware package
External threat actor $\backslash\{\}$ to\$ Tier-1 supplier IT estate	T1566	0.55 (H)	0.55 (H)	8 (L)	C14	INC-04 INC-14 INC-16	Phishing of a supplier with weaker controls
External threat actor $\backslash\{\}$ to\$ Removable media and project files	T1091	0.12 (L)	0.50 (M)	40 (M)	C06 C14	–	Infected removable media carried by field service
External threat actor $\backslash\{\}$ to\$ Machine builder remote access	T1133	0.30 (M)	0.45 (M)	12 (L)	C04 C14	INC-04	Compromise of an integrator maintenance account
EDI / JIT ordering and logistics interface $\backslash\{\}$ to\$ Production stoppage	T1489	0.70 (H)	0.40 (M)	6 (L)	C14 C17	INC-04 INC-14 INC-16 INC-20	Just-in-time starvation halts the line without any OT compromise
EDI / JIT ordering and logistics interface $\backslash\{\}$ to\$ Manufacturing execution system	T1199	0.35 (M)	0.45 (M)	12 (L)	C05 C14	INC-04	Trusted supplier interface terminating inside site operations
OT software and firmware update channel $\backslash\{\}$ to\$ Engineering workstation	T0873	0.50 (H)	0.55 (H)	24 (M)	C09 C06	–	Engineering projects and firmware arrive from vendors as trusted files
Tier-1 supplier IT estate $\backslash\{\}$ to\$ Theft of engineering and design data	T1567.002	0.55 (H)	0.55 (H)	12 (L)	C14	INC-05 INC-15	Suppliers hold OEM drawings and specifications under contract
Tier-1 supplier IT estate $\backslash\{\}$ to\$ EDI / JIT ordering and logistics interface	T1078	0.75 (VH)	0.40 (M)	4 (VL)	C14	INC-04 INC-14 INC-16 INC-20	The supplier's own systems are authorised on the interface by construction
Removable media and project files $\backslash\{\}$ to\$ Engineering workstation	T0847	0.50 (H)	0.55 (H)	8 (L)	C06 C09	–	Field service still moves projects on removable media in many plants
Machine builder remote access $\backslash\{\}$ to\$ Vendor remote-access broker	T1133	0.60 (H)	0.40 (M)	6 (L)	C04	–	Vendor accounts are provisioned on the broker for maintenance
Machine builder remote access $\backslash\{\}$ to\$ Engineering workstation	T0822	0.30 (M)	0.60 (H)	12 (L)	C04 C13	–	Unmanaged cellular or modem access bypassing the IDMZ
CI/CD pipeline and artefact registry $\backslash\{\}$ to\$ Connected-vehicle / telematics back end	T1195.002	0.45 (M)	0.50 (M)	24 (M)	C11	–	Malicious artefact promoted through the pipeline
CI/CD pipeline and artefact registry $\backslash\{\}$ to\$ Manufacturing execution system	T1072	0.28 (M)	0.50 (M)	24 (M)	C05 C09	–	Cloud-driven deployment of plant-side applications
Connected-vehicle / telematics back end $\backslash\{\}$ to\$ Customer personal data breach	T1530	0.70 (H)	0.50 (M)	8 (L)	C16 C11	INC-09	Telemetry back ends hold vehicle and owner records by design
Object storage and data lake $\backslash\{\}$ to\$ Customer personal data breach	T1530	0.90 (VH)	0.60 (H)	2 (VL)	C16	INC-09 INC-10	Reading an exposed store is the whole of the attack once it is found

Table 3: Control catalogue: mitigation m , detection uplift u , recovery effect, relative annualised cost index, and the standard requirements each control implements.

ID	Control	m	u	Recovery	Cost	IEC 62443-3-3	NIST CSF 2.0
C01	Phishing-resistant MFA for remote and privileged access	0.65	0.10	0.00	6	SR 1.1; SR 1.2; SR 1.5; SR 1.7	PR.AA-02; PR.AA-03
C02	Conditional access and device-compliance enforcement	0.40	0.15	0.00	4	SR 1.13; SR 2.6	PR.AA-05
C03	Administrative tiering and privileged access workstations	0.55	0.20	0.00	7	SR 1.1; SR 2.1; SR 1.11	PR.AA-05; PR.PS-01
C04	Brokered, just-in-time vendor remote access	0.60	0.30	0.00	5	SR 1.13; SR 2.6; SR 6.1	PR.AA-05; GV.SC-07
C05	Enforced IT/OT segmentation with an industrial DMZ	0.60	0.25	0.00	8	SR 5.1; SR 5.2; SR 5.3	PR.IR-01
C06	Application allowlisting and removable-media control on OT hosts	0.55	0.15	0.00	5	SR 2.3; SR 3.2	PR.PS-05
C07	Endpoint detection and 24/7 monitored response	0.25	0.45	0.00	7	SR 6.2; SR 3.2	DE.CM-01; DE.CM-09; RS.MA-01
C08	Immutable, offline and exercised backups (IT and OT)	0.05	0.05	0.45	5	SR 7.3; SR 7.4	PR.DS-11; RC.RP-01
C09	Controller change control and program integrity monitoring	0.50	0.35	0.00	6	SR 3.4; SR 3.8; SR 7.6	PR.PS-01; DE.CM-09
C10	Attack-surface management and expedited patching of exposed services	0.45	0.10	0.00	5	SR 7.2; SR 3.10	ID.RA-01; PR.PS-02
C11	SaaS and OAuth token governance	0.45	0.25	0.00	4	SR 1.9; SR 2.1	PR.AA-05; GV.SC-06
C12	Identity lifecycle hygiene and dormant credential revocation	0.70	0.10	0.00	3	SR 1.3; SR 1.5	PR.AA-01; GV.SC-07
C13	Continuous OT network monitoring and asset inventory	0.05	0.50	0.00	6	SR 6.2; SR 7.8	ID.AM-01; DE.CM-01
C14	Supplier security assurance and contractual telemetry	0.35	0.20	0.00	6	SR 1.13; SR 6.1	GV.SC-01; GV.SC-04; GV.SC-08
C15	Service-desk identity proofing and insider-risk programme	0.55	0.25	0.00	3	SR 1.1; SR 2.10	PR.AA-01; GV.RR-02
C16	Cloud security and data-exposure posture management	0.55	0.30	0.00	4	SR 4.1; SR 4.3	PR.DS-01; PR.DS-10; ID.RA-01
C17	Operational resilience: buffers, manual fallback and degraded mode	0.10	0.00	0.55	7	SR 7.1; SR 7.4	RC.RP-01; RC.RP-05; GV.SC-08

Table 4: Consequence model. Durations and fixed costs are triangular. The outage of a campaign that traverses a recovery-inhibiting asset is multiplied: Backup infrastructure $\times 1.8$, Endpoint management / software deployment $\times 1.25$, OT domain controller $\times 1.15$.

Consequence	Downtime h (min, mode, max)	Loss rate (M\$/h)	Fixed cost (M\$, min, mode, max)	Safety
Production stoppage	(24, 120, 840)	1.05	(5, 25, 120)	no
Silent quality degradation / recall	(0, 8, 72)	1.05	(10, 90, 400)	no
Loss of safety function	(48, 168, 720)	1.05	(20, 150, 600)	yes
Theft of engineering and design data	—	—	(5, 40, 250)	no
Customer personal data breach	—	—	(3, 25, 180)	no